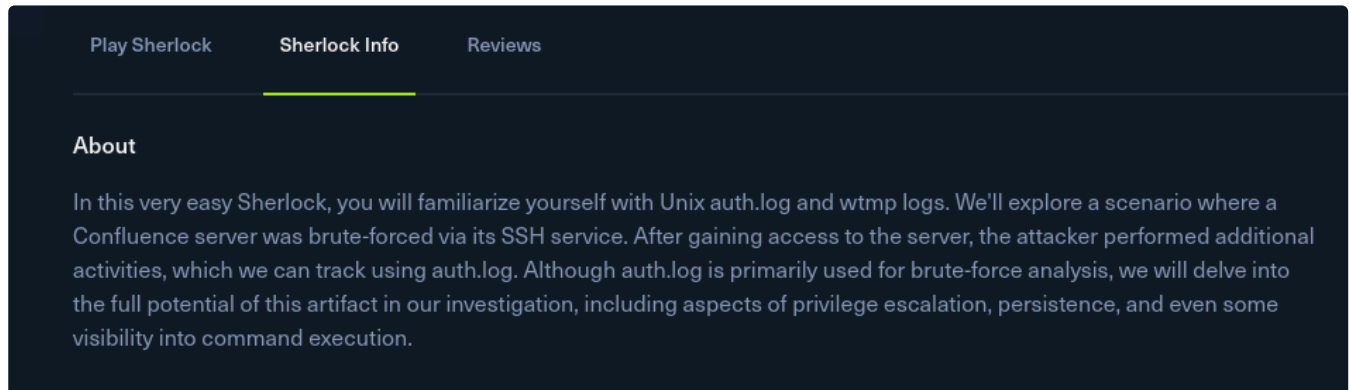


Brutus

И так погнали разбор `Brutus`, для начала давай те посмотрим `Sherlock Info`, чтобы была полная картина.



Перевод:

В этом очень простом Sherlock вы познакомитесь с логами Unix auth.log и wtmp. Мы рассмотрим сценарий, в котором сервер Confluence был взломан методом перебора паролей через его SSH-сервис. После получения доступа к серверу злоумышленник выполнил ряд дополнительных действий, которые можно отследить с помощью auth.log. Хотя auth.log в первую очередь используется для анализа брутфорс-атак, в ходе расследования мы раскроем весь потенциал этого артефакта, включая аспекты повышения привилегий, закрепления в системе и даже частичную видимость выполнения команд.

Скачиваем .zip файл распаковываем его с помощью `7z x` и название файла и вводим пароль.

```
> 7z x Brutus.zip
7-Zip 26.02 (x64) : Copyright (c) 1999-2026 Igor Pavlov : 2026-06-25
64-bit locale=en_US.UTF-8 Threads:8 OPEN_MAX:4096, ASM

Scanning the drive for archives:
1 file, 5756 bytes (6 KiB)

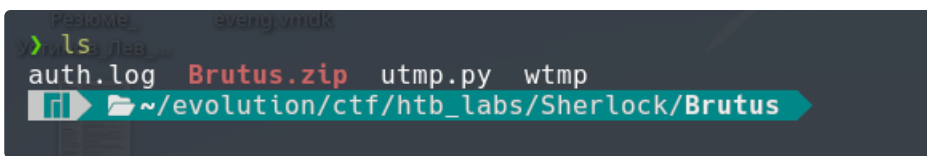
Extracting archive: Brutus.zip
--
Path = Brutus.zip
Type = zip
Physical Size = 5756

Enter password:hacktheblue

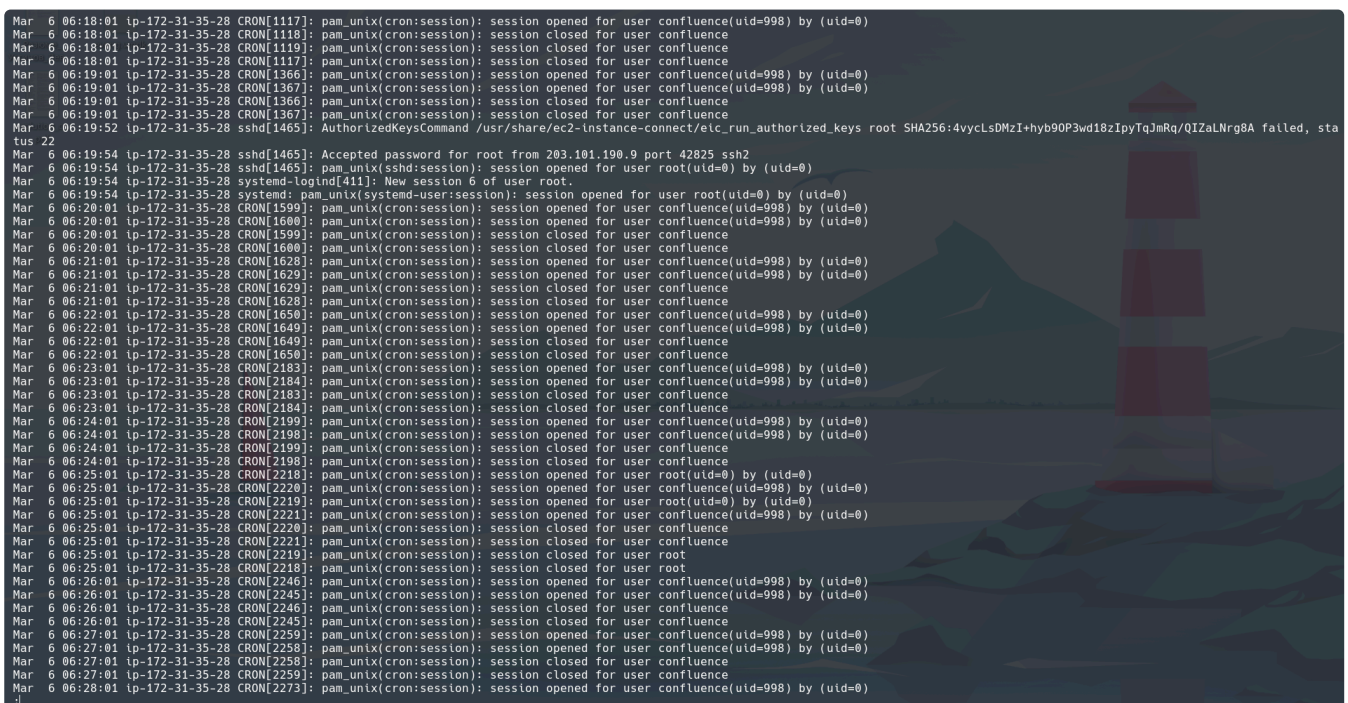
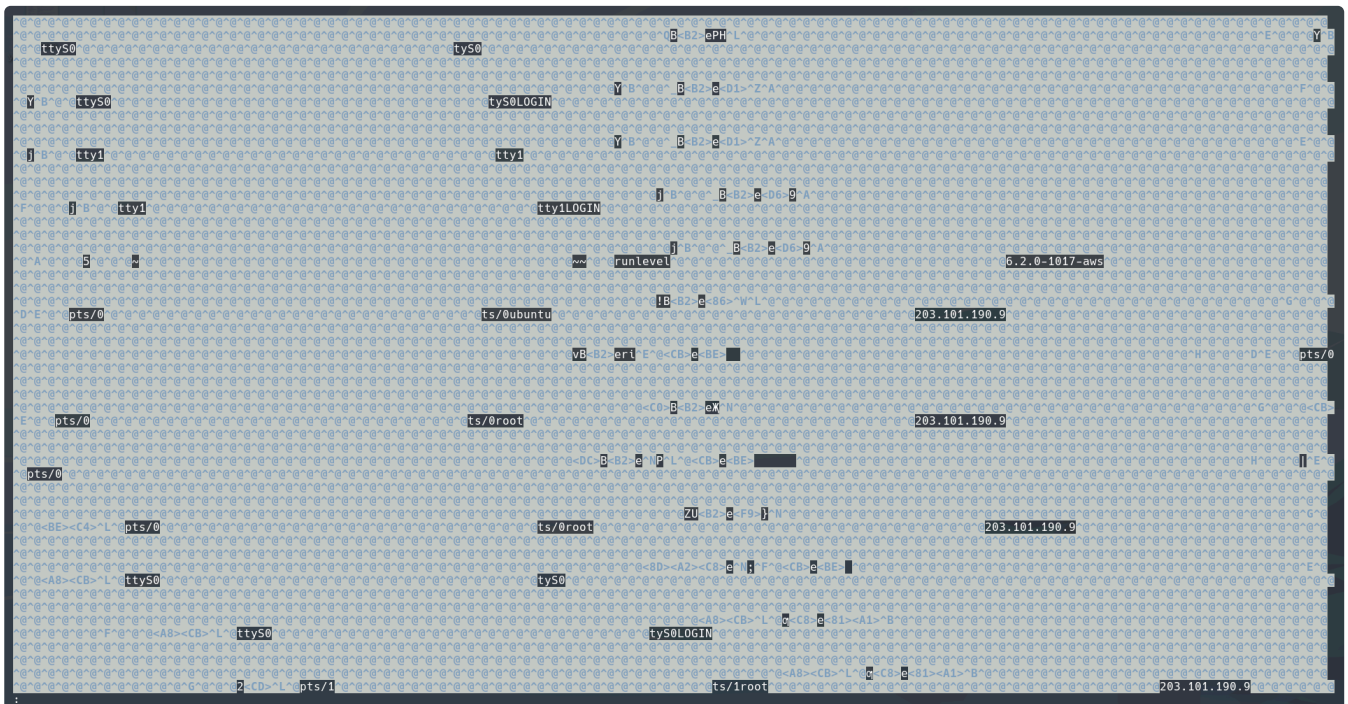
Everything is Ok

Files: 3
Size:      58201
Compressed: 5756
~/evolution/ctf/htb_labs/Sherlock/Brutus |
```

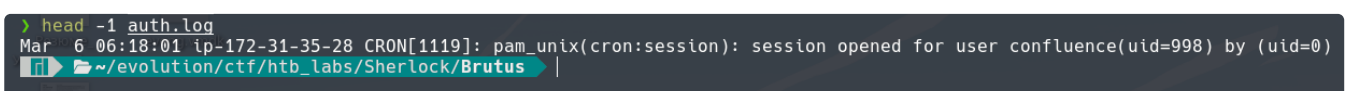
Далее давайте посмотри, что лежало в .zip файле и видим `auth.log`, `utmp.py`, `wtmp`.



Заглянем внутрь *auth.log* and *wtmp* и видим логи в *auth.log* и бинарный файл в *wtmp*.



Мда, нам дали довольно много информации, которую нам нужно как то отфильтровать, чтобы ответить на нужные вопросы. Давай те по подробнее изучим, какие колонки есть в *auth.log*. Для этого давай те воспользуемся *head -1 auth.log*.



И так, у нас есть инфомрации о:

- *месяце*, когда это произошло
- *дата*
- *время*
- *Ip*, с которого все шло
- *Имя процесса с его PID*, то есть по другому номер процесса с его уникальным номером
- *РАМ*, или по другому система аутификации пользователя в Linux
- Последнем сообщении, сессия была открыта каким то пользователем, под root (потому что uid=0, а это только root)

А теперь, давай те уже наконец-то посмотрим человеческом формате логи с `wtmp`, а для этого нам понадобится утилита `utmpdump`, которая преобразует бинарник в приблизительные значения. Воспользуемся ею.

```
> utmpdump wtmp
Utmp dump of wtmp
[2] [00000] [~] [reboot] [~] [6.2.0-1017-aws] [0.0.0.0] [2024-01-25T11:12:17,804944+00:00]
[5] [00601] [tyS0] [ ] [ttyS0] [ ] [0.0.0.0] [2024-01-25T11:12:31,072401+00:00]
[6] [00601] [tyS0] [LOGIN] [ttyS0] [ ] [0.0.0.0] [2024-01-25T11:12:31,072401+00:00]
[5] [00618] [tty1] [ ] [tty1] [ ] [0.0.0.0] [2024-01-25T11:12:31,080342+00:00]
[6] [00618] [tty1] [LOGIN] [tty1] [ ] [0.0.0.0] [2024-01-25T11:12:31,080342+00:00]
[1] [00053] [~] [runlevel] [~] [6.2.0-1017-aws] [0.0.0.0] [2024-01-25T11:12:33,792454+00:00]
[7] [01284] [ts/0] [ubuntu] [pts/0] [203.101.190.9] [203.101.190.9] [2024-01-25T11:13:58,354674+00:00]
[8] [01284] [ ] [ ] [pts/0] [ ] [0.0.0.0] [2024-01-25T11:15:12,956114+00:00]
[7] [01483] [ts/0] [root] [pts/0] [203.101.190.9] [203.101.190.9] [2024-01-25T11:15:40,806926+00:00]
[8] [01404] [ ] [ ] [pts/0] [ ] [0.0.0.0] [2024-01-25T12:34:34,949753+00:00]
[7] [836798] [ts/0] [root] [pts/0] [203.101.190.9] [203.101.190.9] [2024-02-11T10:33:49,408334+00:00]
[5] [838568] [tyS0] [ ] [ttyS0] [ ] [0.0.0.0] [2024-02-11T10:39:02,172417+00:00]
[6] [838568] [tyS0] [LOGIN] [ttyS0] [ ] [0.0.0.0] [2024-02-11T10:39:02,172417+00:00]
[7] [838962] [ts/1] [root] [pts/1] [203.101.190.9] [203.101.190.9] [2024-02-11T10:41:11,700107+00:00]
[8] [838896] [ ] [ ] [pts/1] [ ] [0.0.0.0] [2024-02-11T10:41:46,272984+00:00]
[7] [842171] [ts/1] [root] [pts/1] [203.101.190.9] [203.101.190.9] [2024-02-11T10:54:27,775434+00:00]
[8] [842073] [ ] [ ] [pts/1] [ ] [0.0.0.0] [2024-02-11T11:08:04,769514+00:00]
[8] [836694] [ ] [ ] [pts/0] [ ] [0.0.0.0] [2024-02-11T11:08:04,769963+00:00]
[1] [00000] [~] [shutdown] [~] [6.2.0-1017-aws] [0.0.0.0] [2024-02-11T11:09:18,000731+00:00]
[2] [00000] [~] [reboot] [~] [6.2.0-1018-aws] [0.0.0.0] [2024-03-06T06:17:15,744575+00:00]
[5] [00464] [tyS0] [ ] [ttyS0] [ ] [0.0.0.0] [2024-03-06T06:17:27,354378+00:00]
[6] [00464] [tyS0] [LOGIN] [ttyS0] [ ] [0.0.0.0] [2024-03-06T06:17:27,354378+00:00]
[5] [00505] [tty1] [ ] [tty1] [ ] [0.0.0.0] [2024-03-06T06:17:27,469940+00:00]
[6] [00505] [tty1] [LOGIN] [tty1] [ ] [0.0.0.0] [2024-03-06T06:17:27,469940+00:00]
[1] [00053] [~] [runlevel] [~] [6.2.0-1018-aws] [0.0.0.0] [2024-03-06T06:17:29,538024+00:00]
[7] [01583] [ts/0] [root] [pts/0] [203.101.190.9] [203.101.190.9] [2024-03-06T06:19:55,151913+00:00]
[7] [02549] [ts/1] [root] [pts/1] [65.2.161.68] [65.2.161.68] [2024-03-06T06:32:45,387923+00:00]
[8] [02491] [ ] [ ] [pts/1] [ ] [0.0.0.0] [2024-03-06T06:37:24,590579+00:00]
[7] [02667] [ts/1] [cyberjunkie] [pts/1] [65.2.161.68] [65.2.161.68] [2024-03-06T06:37:35,475575+00:00]
```

Давай те сделаем еще более удобный, воспользуемся `less -S`, она уберет лишнии строки и наведет красоту.

```
[2] [00000] [~] [reboot] [~] [6.2.0-1017-aws] [0.0.0.0] [2024-01-25T11:12:17,804944+00:00]
[5] [00601] [tyS0] [ ] [ttyS0] [ ] [0.0.0.0] [2024-01-25T11:12:31,072401+00:00]
[6] [00601] [tyS0] [LOGIN] [ttyS0] [ ] [0.0.0.0] [2024-01-25T11:12:31,072401+00:00]
[5] [00618] [tty1] [ ] [tty1] [ ] [0.0.0.0] [2024-01-25T11:12:31,080342+00:00]
[6] [00618] [tty1] [LOGIN] [tty1] [ ] [0.0.0.0] [2024-01-25T11:12:31,080342+00:00]
[1] [00053] [~] [runlevel] [~] [6.2.0-1017-aws] [0.0.0.0] [2024-01-25T11:12:33,792454+00:00]
[7] [01284] [ts/0] [ubuntu] [pts/0] [203.101.190.9] [203.101.190.9] [2024-01-25T11:13:58,354674+00:00]
[8] [01284] [ ] [ ] [pts/0] [ ] [0.0.0.0] [2024-01-25T11:15:12,956114+00:00]
[7] [01483] [ts/0] [root] [pts/0] [203.101.190.9] [203.101.190.9] [2024-01-25T11:15:40,806926+00:00]
[8] [01404] [ ] [ ] [pts/0] [ ] [0.0.0.0] [2024-01-25T12:34:34,949753+00:00]
[7] [836798] [ts/0] [root] [pts/0] [203.101.190.9] [203.101.190.9] [2024-02-11T10:33:49,408334+00:00]
[5] [838568] [tyS0] [ ] [ttyS0] [ ] [0.0.0.0] [2024-02-11T10:39:02,172417+00:00]
[6] [838568] [tyS0] [LOGIN] [ttyS0] [ ] [0.0.0.0] [2024-02-11T10:39:02,172417+00:00]
[7] [838962] [ts/1] [root] [pts/1] [203.101.190.9] [203.101.190.9] [2024-02-11T10:41:11,700107+00:00]
[8] [838896] [ ] [ ] [pts/1] [ ] [0.0.0.0] [2024-02-11T10:41:46,272984+00:00]
[7] [842171] [ts/1] [root] [pts/1] [203.101.190.9] [203.101.190.9] [2024-02-11T10:54:27,775434+00:00]
[8] [842073] [ ] [ ] [pts/1] [ ] [0.0.0.0] [2024-02-11T11:08:04,769514+00:00]
[8] [836694] [ ] [ ] [pts/0] [ ] [0.0.0.0] [2024-02-11T11:08:04,769963+00:00]
[1] [00000] [~] [shutdown] [~] [6.2.0-1017-aws] [0.0.0.0] [2024-02-11T11:09:18,000731+00:00]
[2] [00000] [~] [reboot] [~] [6.2.0-1018-aws] [0.0.0.0] [2024-03-06T06:17:15,744575+00:00]
[5] [00464] [tyS0] [ ] [ttyS0] [ ] [0.0.0.0] [2024-03-06T06:17:27,354378+00:00]
[6] [00464] [tyS0] [LOGIN] [ttyS0] [ ] [0.0.0.0] [2024-03-06T06:17:27,354378+00:00]
[5] [00505] [tty1] [ ] [tty1] [ ] [0.0.0.0] [2024-03-06T06:17:27,469940+00:00]
[6] [00505] [tty1] [LOGIN] [tty1] [ ] [0.0.0.0] [2024-03-06T06:17:27,469940+00:00]
[1] [00053] [~] [runlevel] [~] [6.2.0-1018-aws] [0.0.0.0] [2024-03-06T06:17:29,538024+00:00]
[7] [01583] [ts/0] [root] [pts/0] [203.101.190.9] [203.101.190.9] [2024-03-06T06:19:55,151913+00:00]
[7] [02549] [ts/1] [root] [pts/1] [65.2.161.68] [65.2.161.68] [2024-03-06T06:32:45,387923+00:00]
[8] [02491] [ ] [ ] [pts/1] [ ] [0.0.0.0] [2024-03-06T06:37:24,590579+00:00]
[7] [02667] [ts/1] [cyberjunkie] [pts/1] [65.2.161.68] [65.2.161.68] [2024-03-06T06:37:35,475575+00:00]
```

Да, стало намного лучше, можно конечно приступить к поиску ответов, но я не могу не сказать об еще одной утилите, которая мне больше нравится, а именно `last`. Она смотрит, какие пользователи, последние, что то делали в системе, давай те ей тоже воспользуемся и посмотрим ради интереса.

```
> last -f wtmp
cyberju* pts/1 65.2.161.68 Wed Mar 6 16:37 gone - no logout
root pts/1 65.2.161.68 Wed Mar 6 16:32 - 16:37 (00:04)
root pts/0 203.101.190.9 Wed Mar 6 16:19 gone - no logout
reboot system boot 6.2.0-1018-aws Wed Mar 6 16:17 still running
root pts/1 203.101.190.9 Sun Feb 11 20:54 - 21:08 (00:13)
root pts/1 203.101.190.9 Sun Feb 11 20:41 - 20:41 (00:00)
root pts/0 203.101.190.9 Sun Feb 11 20:33 - 21:08 (00:34)
root pts/0 203.101.190.9 Thu Jan 25 21:15 - 22:34 (01:18)
ubuntu pts/0 203.101.190.9 Thu Jan 25 21:13 - 21:15 (00:01)
reboot system boot 6.2.0-1017-aws Thu Jan 25 21:12 - 21:09 (16+23:57)

wtmp begins Thu Jan 25 21:12:17 2024
~/evolution/ctf/htb_labs/Sherlock/Brutus
```

И для того, чтобы поменять время, потому что сейчас отображается не то время, а мое, нам нужно добавить параметр `TZ=utc`. И уже намного лучше.

```
> TZ=utc last -f wtmp
cyberju* pts/1 65.2.161.68 Wed Mar 6 06:37 gone - no logout
root pts/1 65.2.161.68 Wed Mar 6 06:32 - 06:37 (00:04)
root pts/0 203.101.190.9 Wed Mar 6 06:19 gone - no logout
reboot system boot 6.2.0-1018-aws Wed Mar 6 06:17 still running
root pts/1 203.101.190.9 Sun Feb 11 10:54 - 11:08 (00:13)
root pts/1 203.101.190.9 Sun Feb 11 10:41 - 10:41 (00:00)
root pts/0 203.101.190.9 Sun Feb 11 10:33 - 11:08 (00:34)
root pts/0 203.101.190.9 Thu Jan 25 11:15 - 12:34 (01:18)
ubuntu pts/0 203.101.190.9 Thu Jan 25 11:13 - 11:15 (00:01)
reboot system boot 6.2.0-1017-aws Thu Jan 25 11:12 - 11:09 (16+23:57)

wtmp begins Thu Jan 25 11:12:17 2024
~/evolution/ctf/htb_labs/Sherlock/Brutus
```

И еще полезно будет посмотреть, увидеть полное время, для этого воспользуемся флагом `-f`.

```
> TZ=utc last -f wtmp -F
cyberju* pts/1 65.2.161.68 Wed Mar 6 06:37:35 2024 gone - no logout
root pts/1 65.2.161.68 Wed Mar 6 06:32:45 2024 - Wed Mar 6 06:37:24 2024 (00:04)
root pts/0 203.101.190.9 Wed Mar 6 06:19:55 2024 gone - no logout
reboot system boot 6.2.0-1018-aws Wed Mar 6 06:17:15 2024 still running
root pts/1 203.101.190.9 Sun Feb 11 10:54:27 2024 - Sun Feb 11 11:08:04 2024 (00:13)
root pts/1 203.101.190.9 Sun Feb 11 10:41:11 2024 - Sun Feb 11 10:41:46 2024 (00:00)
root pts/0 203.101.190.9 Sun Feb 11 10:33:49 2024 - Sun Feb 11 11:08:04 2024 (00:34)
root pts/0 203.101.190.9 Thu Jan 25 11:15:40 2024 - Thu Jan 25 12:34:34 2024 (01:18)
ubuntu pts/0 203.101.190.9 Thu Jan 25 11:13:58 2024 - Thu Jan 25 11:15:12 2024 (00:01)
reboot system boot 6.2.0-1017-aws Thu Jan 25 11:12:17 2024 - Sun Feb 11 11:09:18 2024 (16+23:57)

wtmp begins Thu Jan 25 11:12:17 2024
~/evolution/ctf/htb_labs/Sherlock/Brutus
```

Теперь, давай те посмотрим, что происходило и какие команды вводились на сервере, для этого давай те по номеру процессора PID посчитаем и отсортируем команды, это можно сделать с помощью такой команды и получаем такой вывод:

```
> awk '{print $5}' auth.log | sed 's/[\[\:].*//g' | sort | uniq -c | sort -n
1 chfn
1 passwd
1 useradd
2 systemd
2 usermod
3 groupadd
6 sudo
8 systemd-logind
104 CRON
257 sshd
```

~/evolution/ctf/htb_labs/Sherlock/Brutus

Разбор команды:

- `awk` - вывод номер столба, в этом случае вывод 5 столбец
- `sed 's/[\[\:].*//g'` - сортирует с помощью регулярных выражений 5 столбец, именно тут, мы убираем PID, чтобы вывелись только команды
- `sort` - сортируем
- `uniq -c` - подсчет команда, которые мы посчитали с их кол-во
- `sort -n` - сортировка по числовому значению в формате возрастания

Давай разберем, что тут вообще происходило:

- `chfn` - замена имени пользователя
- `passwd` - замена пароля пользователя
- `useradd` - добавление нового пользователя
- `systemd` - что то там ковырял в служебных системах
- `groupadd` - добавлял этого нового пользователя в группу (возможно в sudo)
- `sudo` - супер пользователь
- `systemd-logind` - системное логирование
- `CRON` - демон
- `sshd` - проверка ssh

И перенем вывод команды в `log_prog.txt`, чтобы не использовать часто такую длинную команду

```
> awk '{print $5}' auth.log | sed 's/[\[\:].*//g' | sort | uniq -c | sort -n > log_prog.txt
> cat log_prog.txt
1 chfn
1 passwd
1 useradd
2 systemd
2 usermod
3 groupadd
6 sudo
8 systemd-logind
104 CRON
257 sshd
```

~/evolution/ctf/htb_labs/Sherlock/Brutus

Теперь давай те перейдем к вопросу, на которые нам как специалистом, нужно ответить:

1. Analyze the auth.log. What is the IP address used by the attacker to carry out a brute force attack?

Для того, чтобы найти ответ, давай те `grep auth.log` на `sshd` всю и удобным поиском и выводом `less -s`, то есть `grep sshd auth.log | less -S`.

```

Mar  6 06:19:52 172-31-35-28 sshd[1465]: AuthorizedKeysCommand /usr/share/ec2-instance-connect/etc_rn.authorized_keys root SHA256:4vyvLSDmZi+hyb90p3d18zIpyTqJmR/Q1ZaNrg8A failed, st
Mar  6 06:19:52 172-31-35-28 sshd[1465]: Accepted password for root from 203.101.190.9 port 42825 ssh2
Mar  6 06:19:54 172-31-35-28 sshd[1465]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
Mar  6 06:31:31 172-31-35-28 sshd[2325]: Invalid user admin from 65.2.161.68 port 46380
Mar  6 06:31:31 172-31-35-28 sshd[2325]: Received disconnect from 65.2.161.68 port 46380:11: Bye Bye [preauth]
Mar  6 06:31:31 172-31-35-28 sshd[2325]: Disconnected from invalid user admin 65.2.161.68 port 46380 [preauth]
Mar  6 06:31:31 172-31-35-28 sshd[620]: error: banning MaxStartups throttling
Mar  6 06:31:31 172-31-35-28 sshd[620]: drop connection #10 from [65.2.161.68]:46480 on [172.31.35.28]:22 past MaxStartups
Mar  6 06:31:31 172-31-35-28 sshd[2327]: Invalid user admin from 65.2.161.68 port 46392
Mar  6 06:31:31 172-31-35-28 sshd[2327]: pam_unix(sshd:auth): check pass; user unknown
Mar  6 06:31:31 172-31-35-28 sshd[2327]: authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
Mar  6 06:31:31 172-31-35-28 sshd[2332]: Invalid user admin from 65.2.161.68 port 46444
Mar  6 06:31:31 172-31-35-28 sshd[2332]: Invalid user admin from 65.2.161.68 port 46436
Mar  6 06:31:31 172-31-35-28 sshd[2332]: pam_unix(sshd:auth): check pass; user unknown
Mar  6 06:31:31 172-31-35-28 sshd[2332]: authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
Mar  6 06:31:31 172-31-35-28 sshd[2331]: pam_unix(sshd:auth): check pass; user unknown
Mar  6 06:31:31 172-31-35-28 sshd[2331]: authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
Mar  6 06:31:31 172-31-35-28 sshd[2330]: Invalid user admin from 65.2.161.68 port 46422
Mar  6 06:31:31 172-31-35-28 sshd[2337]: Invalid user admin from 65.2.161.68 port 46498
Mar  6 06:31:31 172-31-35-28 sshd[2337]: Invalid user admin from 65.2.161.68 port 46398
Mar  6 06:31:31 172-31-35-28 sshd[2335]: Invalid user admin from 65.2.161.68 port 46460
Mar  6 06:31:31 172-31-35-28 sshd[2337]: pam_unix(sshd:auth): check pass; user unknown
Mar  6 06:31:31 172-31-35-28 sshd[2337]: authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
Mar  6 06:31:31 172-31-35-28 sshd[2335]: pam_unix(sshd:auth): check pass; user unknown
Mar  6 06:31:31 172-31-35-28 sshd[2335]: authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
Mar  6 06:31:31 172-31-35-28 sshd[2334]: Invalid user admin from 65.2.161.68 port 46450
Mar  6 06:31:31 172-31-35-28 sshd[2329]: Invalid user admin from 65.2.161.68 port 46414
Mar  6 06:31:31 172-31-35-28 sshd[2338]: pam_unix(sshd:auth): authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68 user=backup
Mar  6 06:31:31 172-31-35-28 sshd[2330]: pam_unix(sshd:auth): check pass; user unknown
Mar  6 06:31:31 172-31-35-28 sshd[2334]: pam_unix(sshd:auth): check pass; user unknown
Mar  6 06:31:31 172-31-35-28 sshd[2334]: authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68 user=backup
Mar  6 06:31:31 172-31-35-28 sshd[2330]: pam_unix(sshd:auth): authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
Mar  6 06:31:31 172-31-35-28 sshd[2328]: pam_unix(sshd:auth): check pass; user unknown
Mar  6 06:31:31 172-31-35-28 sshd[2328]: authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
Mar  6 06:31:31 172-31-35-28 sshd[2333]: Invalid user admin from 65.2.161.68 port 46452
Mar  6 06:31:31 172-31-35-28 sshd[2329]: pam_unix(sshd:auth): check pass; user unknown
Mar  6 06:31:31 172-31-35-28 sshd[2329]: authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
Mar  6 06:31:31 172-31-35-28 sshd[2333]: pam_unix(sshd:auth): check pass; user unknown
Mar  6 06:31:31 172-31-35-28 sshd[2333]: authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68
Mar  6 06:31:31 172-31-35-28 sshd[2352]: pam_unix(sshd:auth): authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68 user=backup
Mar  6 06:31:31 172-31-35-28 sshd[2351]: pam_unix(sshd:auth): authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68 user=backup
Mar  6 06:31:31 172-31-35-28 sshd[2355]: pam_unix(sshd:auth): authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68 user=backup
Mar  6 06:31:32 172-31-35-28 sshd[2377]: pam_unix(sshd:auth): authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=65.2.161.68 user=backup
Mar  6 06:31:32 172-31-35-28 sshd[2377]: Failed password for invalid user admin from 65.2.161.68 port 46392 ssh2
Mar  6 06:31:33 172-31-35-28 sshd[2331]: Failed password for invalid user admin from 65.2.161.68 port 46436 ssh2
Mar  6 06:31:33 172-31-35-28 sshd[2332]: Failed password for invalid user admin from 65.2.161.68 port 46444 ssh2
Mar  6 06:31:33 172-31-35-28 sshd[2335]: Failed password for invalid user admin from 65.2.161.68 port 46460 ssh2
Mar  6 06:31:33 172-31-35-28 sshd[2337]: Failed password for invalid user admin from 65.2.161.68 port 46498 ssh2
Mar  6 06:31:33 172-31-35-28 sshd[2334]: Failed password for invalid user admin from 65.2.161.68 port 46454 ssh2
Mar  6 06:31:33 172-31-35-28 sshd[2330]: Failed password for backup from 65.2.161.68 port 46512 ssh2

```

Смотря на эти логи, уже можно ответить на первый вопрос, но давай те это мы прям подтвердить и убедимся в правильности нашего ответа, ОГРОМНЫЙ намек идет на `ram_unix`, потому что его слишком много и нужно бы его грепнуть и посмотреть.

```

Mar 6 06:19:52 lwr-172-31-35-28 sshd[1465]: AcceptedKeysCommand /usr/share/ec2-instance-connect/etc_run_authorized_keys root SHA256:4vycLSDmZi+hyb90P3wd18zIpTqJmRq/Q1ZaLnRgBA failed, 3
Mar 6 06:19:54 lwr-172-31-35-28 sshd[1465]: Accepted password for root from 203.101.190.9 port 42825 ssh2
Mar 6 06:31:31 lwr-172-31-35-28 sshd[2325]: Invalid user admin from 65.2.161.68 port 46380
Mar 6 06:31:31 lwr-172-31-35-28 sshd[2325]: Received disconnect from 65.2.161.68 port 46380:11: Bye Bye [preauth]
Mar 6 06:31:31 lwr-172-31-35-28 sshd[2325]: Disconnected from invalid user admin 65.2.161.68 port 46380 [preauth]
Mar 6 06:31:31 lwr-172-31-35-28 sshd[620]: error: beginning MaxStartups throttling
Mar 6 06:31:31 lwr-172-31-35-28 sshd[620]: Max connection #19 from 65.2.161.68 port 46482 on [172.31.35.28]:22 past MaxStartups
Mar 6 06:31:31 lwr-172-31-35-28 sshd[2327]: Invalid user admin from 65.2.161.68 port 46392
Mar 6 06:31:31 lwr-172-31-35-28 sshd[2327]: Invalid user admin from 65.2.161.68 port 46444
Mar 6 06:31:31 lwr-172-31-35-28 sshd[2331]: Invalid user admin from 65.2.161.68 port 46436
Mar 6 06:31:31 lwr-172-31-35-28 sshd[2330]: Invalid user admin from 65.2.161.68 port 46422
Mar 6 06:31:31 lwr-172-31-35-28 sshd[2337]: Invalid user admin from 65.2.161.68 port 46498
Mar 6 06:31:31 lwr-172-31-35-28 sshd[2328]: Invalid user admin from 65.2.161.68 port 46390
Mar 6 06:31:31 lwr-172-31-35-28 sshd[2335]: Invalid user admin from 65.2.161.68 port 46460
Mar 6 06:31:31 lwr-172-31-35-28 sshd[2334]: Invalid user admin from 65.2.161.68 port 46454
Mar 6 06:31:31 lwr-172-31-35-28 sshd[2329]: Invalid user admin from 65.2.161.68 port 46414
Mar 6 06:31:31 lwr-172-31-35-28 sshd[2333]: Invalid user admin from 65.2.161.68 port 46452
Mar 6 06:31:33 lwr-172-31-35-28 sshd[2327]: Failed password for invalid user admin from 65.2.161.68 port 46392 ssh2
Mar 6 06:31:33 lwr-172-31-35-28 sshd[2331]: Failed password for invalid user admin from 65.2.161.68 port 46436 ssh2
Mar 6 06:31:33 lwr-172-31-35-28 sshd[2330]: Failed password for invalid user admin from 65.2.161.68 port 46422 ssh2
Mar 6 06:31:33 lwr-172-31-35-28 sshd[2337]: Failed password for invalid user admin from 65.2.161.68 port 46498 ssh2
Mar 6 06:31:33 lwr-172-31-35-28 sshd[2328]: Failed password for invalid user admin from 65.2.161.68 port 46414 ssh2
Mar 6 06:31:33 lwr-172-31-35-28 sshd[2335]: Failed password for backup from 65.2.161.68 port 46452 ssh2
Mar 6 06:31:33 lwr-172-31-35-28 sshd[2334]: Failed password for backup from 65.2.161.68 port 46468 ssh2
Mar 6 06:31:33 lwr-172-31-35-28 sshd[2330]: Failed password for invalid user admin from 65.2.161.68 port 46422 ssh2
Mar 6 06:31:33 lwr-172-31-35-28 sshd[2328]: Failed password for invalid user admin from 65.2.161.68 port 46390 ssh2
Mar 6 06:31:33 lwr-172-31-35-28 sshd[2329]: Failed password for invalid user admin from 65.2.161.68 port 46414 ssh2
Mar 6 06:31:33 lwr-172-31-35-28 sshd[2333]: Failed password for invalid user admin from 65.2.161.68 port 46452 ssh2
Mar 6 06:31:34 lwr-172-31-35-28 sshd[2352]: Failed password for backup from 65.2.161.68 port 46568 ssh2
Mar 6 06:31:34 lwr-172-31-35-28 sshd[2351]: Failed password for backup from 65.2.161.68 port 46538 ssh2
Mar 6 06:31:34 lwr-172-31-35-28 sshd[2355]: Failed password for backup from 65.2.161.68 port 46576 ssh2
Mar 6 06:31:34 lwr-172-31-35-28 sshd[2357]: Failed password for backup from 65.2.161.68 port 46582 ssh2
Mar 6 06:31:34 lwr-172-31-35-28 sshd[2327]: Received disconnect from 65.2.161.68 port 46392:11: Bye Bye [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2327]: Received disconnect from 65.2.161.68 port 46392:11: Bye Bye [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2332]: Received disconnect from 65.2.161.68 port 46444:11: Bye Bye [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2332]: Disconnected from invalid user admin 65.2.161.68 port 46444 [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2331]: Received disconnect from 65.2.161.68 port 46436:11: Bye Bye [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2331]: Disconnected from invalid user admin 65.2.161.68 port 46436 [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2327]: Received disconnect from 65.2.161.68 port 46498:11: Bye Bye [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2337]: Disconnected from invalid user admin 65.2.161.68 port 46498 [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2328]: Received disconnect from 65.2.161.68 port 46390:11: Bye Bye [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2328]: Disconnected from invalid user admin 65.2.161.68 port 46390 [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2330]: Received disconnect from 65.2.161.68 port 46422:11: Bye Bye [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2330]: Disconnected from invalid user admin 65.2.161.68 port 46422 [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2334]: Received disconnect from 65.2.161.68 port 46454:11: Bye Bye [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2334]: Disconnected from invalid user admin 65.2.161.68 port 46454 [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2335]: Received disconnect from 65.2.161.68 port 46460:11: Bye Bye [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2335]: Disconnected from invalid user admin 65.2.161.68 port 46460 [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2329]: Received disconnect from 65.2.161.68 port 46414:11: Bye Bye [preauth]
Mar 6 06:31:35 lwr-172-31-35-28 sshd[2329]: Disconnected from invalid user admin 65.2.161.68 port 46414 [preauth]

```

И тут мы конечно, может догадаться, что это Brutforce атака, давай те это рекурсивно, с помощью `grep` проверим.

И опа, мы нашли его, у него получилось ввойти в сервер, давай те теперь, мы посмотри успешные входы.

```
> grep ssh_auth.log | grep -v pam_unix | grep 'Accepted password'
Mar  6 06:19:54 ip-172-31-35-28 sshd[1465]: Accepted password for root from 203.101.190.9 port 42825 ssh2
Mar  6 06:31:40 ip-172-31-35-28 sshd[2411]: Accepted password for root from 65.2.161.68 port 34782 ssh2
Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
Mar  6 06:37:34 ip-172-31-35-28 sshd[2667]: Accepted password for cyberjunkie from 65.2.161.68 port 43260 ssh2
```

Вывод, конечно не удачный, давай те попробуем еще по брутформ Ip поискать.

```
> grep ssh_auth.log | grep -v pam_unix | grep 'Accepted password' | grep 65.2.161.68
Mar  6 06:31:40 ip-172-31-35-28 sshd[2411]: Accepted password for root from 65.2.161.68 port 34782 ssh2
Mar  6 06:32:44 ip-172-31-35-28 sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
Mar  6 06:37:34 ip-172-31-35-28 sshd[2667]: Accepted password for cyberjunkie from 65.2.161.68 port 43260 ssh2
```

И тут можно уже понять, что `cyberjunkie` был добавлен `root`. И пробуем наш ответ. И это верно.

Task 2 Hint

The bruteforce attempts were successful and attacker gained access to an account on the server. What is the username of the account?

`root` Submit Task

3. Identify the UTC timestamp when the attacker logged in manually to the server and established a terminal session to carry out their objectives. The login time will be different than the authentication time, and can be found in the wtmp artifact.

Для ответа на этот вопрос, можно воспользоваться `wtmp` файлом и посмотреть время.

```
> TZ=utc last -f wtmp -F
cyberju* pts/1      65.2.161.68      Wed Mar  6 06:37:35 2024      gone - no logout
root     pts/1      65.2.161.68      Wed Mar  6 06:32:45 2024 - Wed Mar  6 06:37:24 2024  (00:04)
root     pts/0      203.101.190.9    Wed Mar  6 06:19:55 2024      gone - no logout
reboot   system boot  6.2.0-1018-aws   Wed Mar  6 06:17:15 2024      still running
root     pts/1      203.101.190.9    Sun Feb 11 10:54:27 2024 - Sun Feb 11 11:08:04 2024  (00:13)
root     pts/1      203.101.190.9    Sun Feb 11 10:41:11 2024 - Sun Feb 11 10:41:46 2024  (00:00)
root     pts/0      203.101.190.9    Sun Feb 11 10:33:49 2024 - Sun Feb 11 11:08:04 2024  (00:34)
root     pts/0      203.101.190.9    Thu Jan 25 11:15:40 2024 - Thu Jan 25 12:34:34 2024  (01:18)
ubuntu   pts/0      203.101.190.9    Thu Jan 25 11:13:58 2024 - Thu Jan 25 11:15:12 2024  (00:01)
reboot   system boot  6.2.0-1017-aws   Thu Jan 25 11:12:17 2024 - Sun Feb 11 11:09:18 2024  (16+23:57)

wtmp begins Thu Jan 25 11:12:17 2024
```

И тут прекрасно видно ответ, код написан внизу, а именно 2024 у нас.

Task 3 Hint

Identify the UTC timestamp when the attacker logged in manually to the server and established a terminal session to carry out their objectives. The login time will be different than the authentication time, and can be found in the wtmp artifact.

`2024-03-06 06:32:45` Submit Task

И правильно !

4. SSH login sessions are tracked and assigned a session number upon login. What is the session number assigned to the attacker's session for the user account from Question 2?

Для этого гребним и посмотрим, какие были сессии.

```
> grep systemd-logind auth.log
Mar  6 06:19:54 ip-172-31-35-28 systemd-logind[411]: New session 6 of user root.
Mar  6 06:31:40 ip-172-31-35-28 systemd-logind[411]: New session 34 of user root.
Mar  6 06:31:40 ip-172-31-35-28 systemd-logind[411]: Session 34 logged out. Waiting for processes to exit.
Mar  6 06:31:40 ip-172-31-35-28 systemd-logind[411]: Removed session 34.
Mar  6 06:32:44 ip-172-31-35-28 systemd-logind[411]: New session 37 of user root.
Mar  6 06:37:24 ip-172-31-35-28 systemd-logind[411]: Session 37 logged out. Waiting for processes to exit.
Mar  6 06:37:24 ip-172-31-35-28 systemd-logind[411]: Removed session 37.
Mar  6 06:37:34 ip-172-31-35-28 systemd-logind[411]: New session 49 of user cyberjunkie.
```

И давай те попробуем 37 и это правильный ответ.

Task 4

Hint

SSH login sessions are tracked and assigned a session number upon login. What is the session number assigned to the attacker's session for the user account from Question 2?

37

Submit Task

5. The attacker added a new user as part of their persistence strategy on the server and gave this new user account higher privileges. What is the name of this account?

Ну тут мы уже знаем из за логической цепочки.

Task 5

Hint

The attacker added a new user as part of their persistence strategy on the server and gave this new user account higher privileges. What is the name of this account?

cyberjunkie

Submit Task

6. What is the MITRE ATT&CK sub-technique ID used for persistence by creating a new account?

Для ответа на этот вопрос, нам нужен google. Гуглим MITRE ATT&CK.

MITRE ATT&CK

Google

MITRE ATT&CK

Режим ИИ Все Картинки Видео Покупки Новости Короткие видео Ещё Инструменты

MITRE ATT&CK

https://attack.mitre.org · Перевести эту страницу

MITRE ATT&CK®

MITRE ATT&CK® is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is ...

Enterprise Matrix

Enterprise Matrix. Below are the tactics and techniques ...

Techniques

An adversary accomplishes a reflection attack by sending ...

Tactics

Enterprise tactics. Tactics represent the "why" of an ATT ...

ATT&CK Data & Tools

The ATT&CK Navigator is a web-based tool for annotating and ...

Get Started

ATT&CK focuses on how adversaries interact with ...

Другие результаты с сайта mitre.org

ptsecurity.com

https://mitre.ptsecurity.com

Матрица MITRE ATT&CK

Матрица MITRE ATT&CK описывает тактики и техники, которыми злоумышленники пользуются в своих атаках на корпоративную инфраструктуру. Покрытие продуктами 81%.

Хабр

https://habr.com / companies / jetinfostystems / articles

Это база. MITRE ATT&CK

25 мар. 2024 г. — Mad20.io — учебные курсы и сертификации MAD20™, основанные на программе MITRE ATT&CK Defender™. В прошлом году все курсы можно было посмотреть ...

attack.mitre.org/matrices/enterprise/

Заходим по первой ссылке и дальше нам нужно зайти в **Create Account** в колонке **Persistence**

MITRE | ATT&CK®

Matrices Tactics Techniques Defenses CTI Resources Benefactors Contribute Blog Search

ATT&CKcon 7.0 in-person tickets are open! Join us October 27-28, 2026 in McLean, VA. Register here for in-person tickets; hotel and location details can be found in the FAQ.

ATT&CK®

Get Started Take a Tour

Contribute Blog

FAQ Random Page

MITRE ATT&CK® is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is used as a foundation for the development of specific threat models and methodologies in the private sector, in government, and in the cybersecurity product and service community.

With the creation of ATT&CK, MITRE is fulfilling its mission to solve problems for a safer world — by bringing communities together to develop more effective cybersecurity. ATT&CK is open and available to any person or organization for use at no charge.

ATT&CK Matrix for Enterprise

layout: side show sub-techniques hide sub-techniques

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Stealth	Defense Impairment	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
12 techniques	9 techniques	11 techniques	20 techniques	22 techniques	13 techniques	30 techniques	18 techniques	17 techniques	34 techniques	9 techniques	17 techniques	18 techniques	9 techniques	15 techniques
Active Scanning (2)	Acquire Access	Content Injection	BITS Jobs	Account Manipulation (7)	Abuse Elevation Control Mechanism (6)	Access Token Manipulation (3)	Disable or Modify System Firewall (3)	Adversary-in-the-Middle (4)	Account Discovery (4)	Exploitation of Remote Services	Adversary-in-the-Middle (4)	Application Layer Protocol (3)	Automated Exfiltration (1)	Account Access Removal
Gather Victim Host Information (4)	Acquire Infrastructure (8)	Drive-by Compromise	Cloud Administration Command	BITS Jobs	Access Token Manipulation (3)	BITS Jobs	Disable or Modify Tools (4)	Brute Force (4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (3)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction (1)
Gather Victim Identity Information (3)	Compromise Accounts (2)	Exploit Public-Facing Application	Command and Scripting Interpreter (13)	Boot or Logon Autostart Execution (14)	Account Manipulation (7)	Build Image on Host	Domain or Tenant Policy Modification (2)	Credentials from Password Stores (6)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Content Injection	Exfiltration Over Alternative Protocol (3)	Data Encrypted for Impact
Gather Victim Network Information (6)	Compromise Infrastructure (8)	External Remote Services	Container Administration Command	Boot or Logon Initialization Scripts (3)	Boot or Logon Autostart Execution (14)	Debugger Evasion	Downgrade Attack	Exploitation for Credential Access	Exploitation for Credential Access	Remote Service Session Hijacking (2)	Automated Collection	Content Injection	Exfiltration Over Alternative Protocol (3)	Data Manipulation (3)
Gather Victim Org Information (4)	Develop Capabilities (4)	Hardware Additions	ESXi Administration Command	Cloud Application Integration	Boot or Logon Initialization Scripts (3)	Delay Execution	Decobfuscate/Decode Files or Information	Forced Authentication	Cloud Infrastructure Discovery	Cloud Service Session Hijacking (2)	Browser Session Hijacking	Data Encoding (2)	Exfiltration Over C2 Channel	Defacement (2)
Phishing for Information (4)	Establish Accounts (3)	Phishing (4)	Deploy Container	Compromise Host Software Binary	Boot or Logon Initialization Scripts (3)	Direct Volume Access	Exploitation for Defense Impairment	Forge Web Credentials (2)	Cloud Service Dashboard	Remote Services (8)	Clipboard Data	Data Obfuscation (3)	Exfiltration Over Other Network Medium (1)	Disk Wipe (2)
Query Public AI Services	Generate Content (2)	Replication Through Removable Media	ESXi Administration Command	Create or Modify System Process (3)	Domain or Tenant Policy Modification (2)	Execution Guardrails (2)	File and Directory Permissions Modification (2)	Input Capture (4)	Cloud Service Discovery	Replication Through Removable Media	Data from Cloud Storage	Dynamic Resolution (3)	Exfiltration Over Physical Medium (1)	Email Bombing
Search Closed Sources (1)	Obtain Capabilities (7)	Supply Chain	Exploitation for Client Execution	Create Account (3)	Domain or Tenant Policy Modification (2)	Exploitation for Stealth	Modify Authentication	Modify Authentication Process (3)	Cloud Storage Object Discovery	Software Deployment	Data from Configuration Repository (2)	Encrypted Channel (2)	Exfiltration Over Physical Medium (1)	Endpoint Denial of Service (4)
	Stage Capabilities (1)		Hijack Execution Flow (1)	Create or								Failback	Exfiltration	Financial Theft
														Firmware Corruption

MITRE ATT&CK

Home > Techniques > Enterprise > Create Account

Create Account

Sub-techniques (3)

Adversaries may create an account to maintain access to victim systems.^[1] With a sufficient level of access, creating such accounts may be used to establish secondary credentialed access that do not require persistent remote access tools to be deployed on the system.

Accounts may be created on the local system or within a domain or cloud tenant. In cloud environments, adversaries may create accounts that only have access to specific services, which can reduce the chance of detection.

ID: T1136
Sub-techniques: T1136.001, T1136.002, T1136.003
Tactic: Persistence
Platforms: Containers, ESXi, IaaS, Identity Provider, Linux, Network Devices, Office Suite, SaaS, Windows, macOS
Contributors: Austin Clark, @c2defense; Microsoft Threat Intelligence Center (MSTIC); Praetorian
Version: 2.6
Created: 14 December 2017
Last Modified: 24 October 2025

Version Permalink

Procedure Examples

ID	Name	Description
C0025	2016 Ukraine Electric Power Attack	During the 2016 Ukraine Electric Power Attack, Sandworm Team added a login to a SQL Server with <code>sp_addlinkedserverlogin</code> . ^[2]
G0119	Indrik Spider	Indrik Spider used <code>wmic.exe</code> to add a new user to the system. ^[1]
S1199	LockBit 2.0	LockBit 2.0 has been observed creating accounts for persistence using simple names like "a". ^[3]
G1045	Salt Typhoon	Salt Typhoon has created Linux-level users on compromised network devices through modification of <code>/etc/shadow</code> and <code>/etc/passwd</code> . ^[4]
G1015	Scattered Spider	Scattered Spider creates new user identities within the compromised organization. ^[5]

И нас тут интересует Sub-technique и выбираем первый вариант) и он подходит.

Task 6

What is the MITRE ATT&CK sub-technique ID used for persistence by creating a new account?

T1136.001

Submit Task

7. What time did the attacker's first SSH session end according to auth.log?

Для ответа, так же воспользуемся `last` и просто считаем

```
TZ=utc last -f wtmp -F
cyberju* pts/1 65.2.161.68 Wed Mar 6 06:37:35 2024 gone - no logout
root pts/1 65.2.161.68 Wed Mar 6 06:32:45 2024 - Wed Mar 6 06:37:24 2024 (00:04)
root pts/0 203.101.190.9 Wed Mar 6 06:19:55 2024 gone - no logout
reboot system boot 6.2.0-1018-aws Wed Mar 6 06:17:15 2024 still running
root pts/1 203.101.190.9 Sun Feb 11 10:54:27 2024 - Sun Feb 11 11:08:04 2024 (00:13)
root pts/1 203.101.190.9 Sun Feb 11 10:41:11 2024 - Sun Feb 11 10:41:46 2024 (00:00)
root pts/0 203.101.190.9 Sun Feb 11 10:33:49 2024 - Sun Feb 11 11:08:04 2024 (00:34)
root pts/0 203.101.190.9 Thu Jan 25 11:15:40 2024 - Thu Jan 25 12:34:34 2024 (01:18)
ubuntu pts/0 203.101.190.9 Thu Jan 25 11:13:58 2024 - Thu Jan 25 11:15:12 2024 (00:01)
reboot system boot 6.2.0-1017-aws Thu Jan 25 11:12:17 2024 - Sun Feb 11 11:09:18 2024 (16+23:57)

wtmp begins Thu Jan 25 11:12:17 2024
~/evolution/ctf/htb_labs/Sherlock/Brutus
```

8. The attacker logged into their backdoor account and utilized their higher privileges to download a script. What is the full command executed using sudo?

А для ответа на такой вопрос, так же проанализируем `auth.log` от `sudo` потому что его выполняли.